

Thesis Proposal

Title: Co-Adaptive Autonomous Defense Against Advanced Active Directory Certificate Services (ESC13-ESC15) Exploits in Multi-Forest Environments

1. Introduction and Background

The modern enterprise attack surface has transitioned from a static perimeter into a dense, dynamic graph characterized by interconnected identities, authorization tokens, and trust boundaries. Within this paradigm, Active Directory Certificate Services (AD CS) has emerged as a primary vector for devastating privilege escalation and lateral movement. Despite its utility in managing Public Key Infrastructure (PKI), AD CS is frequently misconfigured, allowing low-privileged actors to request certificates that imperceptibly impersonate highly privileged administrative identities.

2. Problem Statement

Recent discoveries in AD CS, specifically the techniques designated ESC13, ESC14, and ESC15 (CVE-2024-49019 "EKUwu"), represent the absolute vanguard of architectural abuses. ESC15, for instance, exploits legacy interactions within Schema Version 1 templates, allowing an unprivileged attacker to inject arbitrary Application Policies into a Certificate Signing Request (CSR) to override intended security constraints.

The systemic risk of these vulnerabilities is exponentially magnified in multi-forest environments, where exploits originating in an isolated child domain can seamlessly traverse cross-forest trusts. Defending these networks dynamically is a monumental challenge; calculating the optimal edge-blocking strategy to sever an attack path is mathematically proven to be fundamentally NP-hard. Furthermore, researching AI-driven defense typically requires resource-heavy, full-OS virtual machines, which is computationally prohibitive for hardware constrained to 5GB of RAM.

3. Research Objectives and Novelty

This research aims to transition Active Directory defense from static graph analysis to a dynamic, mathematical "Digital Twin" simulation capable of operating efficiently on standard consumer hardware. The core novelties of this research include:

- 1. Zero-Day Exploit Modeling:** Formally defining the absolute newest AD CS vectors (ESC13-ESC15) as mathematical graph state transitions, bypassing heavy cryptographic overhead. These vectors remain completely unmodeled in current autonomous defense literature.
- 2. Multi-Forest Scalability:** Extending single-domain reinforcement learning frameworks to handle the complex trust boundaries, SID filtering mechanisms, and topological scales inherent to multi-forest architectures.
- 3. Explainable AI (XAI) Integration:** Implementing GNNExplainer to translate abstract

mathematical edge-blocking decisions into human-readable, actionable security policies, solving the "black-box" trust gap within Security Operations Centers (SOC).

4. Operational Challenges and Constraints

Implementing a co-adaptive cyber defense framework introduces several critical operational hurdles that this research will explicitly address:

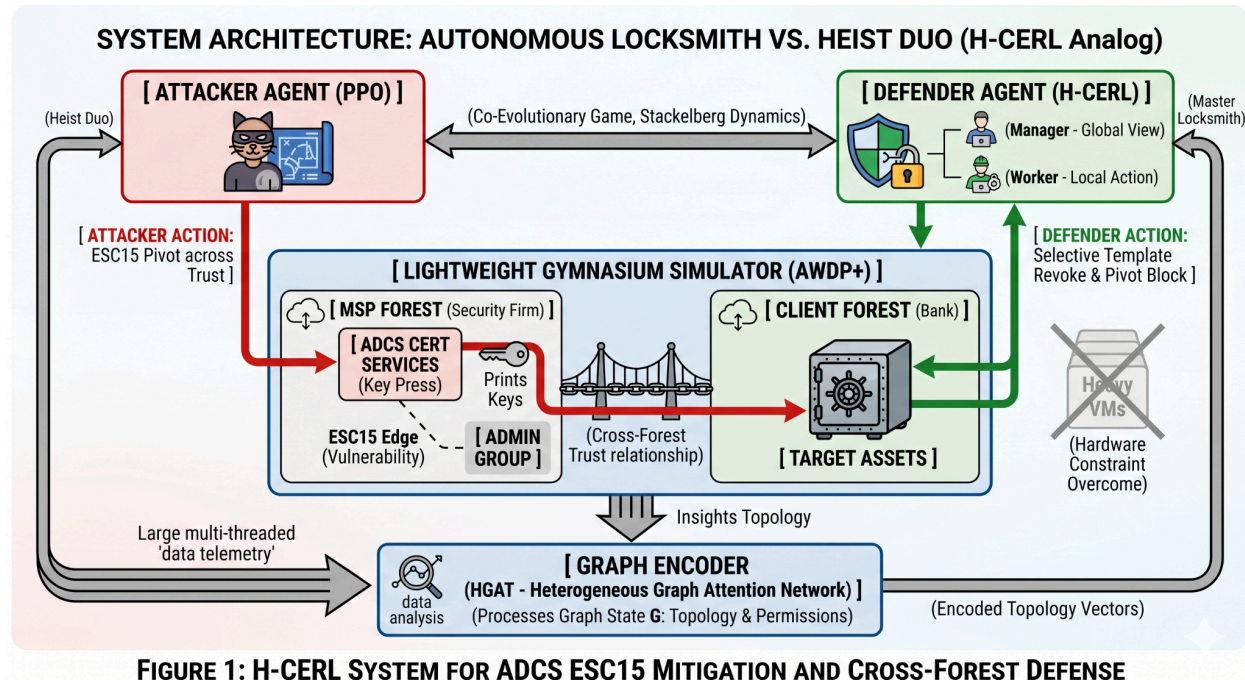
1. **Combinatorial Explosion:** Multi-forest environments contain thousands of nodes and edges. Processing this scale through standard Graph Neural Networks (GNNs) can easily exceed 5GB RAM limits, causing out-of-memory training failures.
2. **Reward Hacking:** Autonomous agents may learn that the mathematically easiest way to secure a network is to permanently sever all cross-forest trusts, achieving absolute security at the cost of catastrophic denial-of-service to legitimate business operations.
3. **Algorithmic Non-Stationarity:** When an attacker agent and a defender agent continuously adapt to each other in parallel, the environment becomes highly non-stationary, preventing models from converging to a stable equilibrium.
4. **The Sim-to-Real Gap:** Simplifying complex cryptographic enrollments into pure mathematical simulations risks creating AI models that fail to understand real-world cybersecurity prerequisites.

5. Proposed Solution Architecture

To bypass computational bottlenecks while maintaining theoretical rigor, this research will leverage the **Automated Windows Domain Penetration (AWDP)** framework natively integrated with OpenAI Gymnasium. Vulnerabilities like ESC15 will be mapped programmatically as pure $O(1)$ graph state transitions.

The network topology will be processed using a **Heterogeneous Graph Attention Network (HGAT)**, utilizing node-level and semantic-level attention mechanisms to evaluate the identity blast radius of vulnerable templates. To circumvent RAM constraints, the architecture will utilize PyTorch Geometric's NeighborLoader to process the graph in memory-efficient sub-batches.

To solve the NP-hard defense problem, the research will deploy **Hierarchical Multi-Agent Reinforcement Learning (H-MARL)** structured as a Bayesian Stackelberg game. A "Master" agent will dictate cross-forest strategies, while localized "Worker" agents handle targeted edge-blocking. The system's decisions will be decoded using GNNExplainer, acting as a translator for human analysts.



6. Implementation Methodology

The project will be executed through a rigorous six-phase methodology:

1. **Phase 1: Foundation and Simulator Extension:** The research will clone the Python-based AWDP Gymnasium environment and manually extend the state machine classes to introduce specialized mathematical node types for Certificate_Template and Enterprise_CA.
2. **Phase 2: Mathematical Exploit Logic Integration:** ESC13-ESC15 vulnerabilities will be defined programmatically. Logic will be written stating that if an attacker node holds an Enroll edge to a Schema V1 template with the "Supply in the request" flag enabled, the environment instantly grants a direct impersonation edge to the Domain Admin.
3. **Phase 3: Multi-Forest Data Generation:** To ensure computational feasibility on 5GB of RAM, the open-source ADSynth tool will generate realistic synthetic Active Directory attack graphs strictly capped at the r500 dataset (500-node network). These JSON files will be formatted into PyTorch Geometric HeteroData tensors.
4. **Phase 4: ML Architecture and XAI Construction:** The HGAT graph encoder will be built using PyTorch Geometric, explicitly implementing Neighbor Sampling optimization. A Dueling Double Deep Q-Network (DDQN) will be established for the attacker, alongside a hierarchical model for the defender. GNNExplainer will be integrated natively to extract predictive subgraphs.
5. **Phase 5: Co-Adaptive Training Loop:** Parallel Stackelberg gameplay will be initiated. To prevent reward hacking, an asymmetric reward function will be formulated to penalize the AI for disrupting legitimate business operations, defined mathematically as:

$$R = w_g \cdot 1_{\text{target}} - w_c \cdot \text{Cost}(a) - w_v \cdot P(\text{alert}|a, S_t)$$

6. **Phase 6: Mathematical Proofs and Final Evaluation:** The research will draft formal proofs reducing the AD edge-blocking problem to the NP-hard Multi-way Cut problem. Stochastic Approximation and the Ordinary Differential Equation (ODE) method will be leveraged to formally prove the H-MARL agent converges to a stable equilibrium.

7. Expected Outcomes and Academic Impact

By anchoring advanced deep learning in strict mathematical formalisms (NP-hardness proofs and ODE stability) rather than resource-intensive virtual machines, this methodology transitions applied IT penetration testing into rigorous theoretical computer science. The resulting framework will operate flawlessly within lower RAM constraints while producing the original, scalable empirical data demanded by top-tier Q1 cybersecurity journals, such as the IEEE Transactions on Dependable and Secure Computing. Furthermore, the integration of Explainable AI bridges the gap between academic theory and practical enterprise adoption, directly addressing the modern needs of hybrid cloud security.